

#11 · Webhook 去重

[修復] 技術代號 D-PO-4 · 約 1 天

一句話：外部通知會被重複處理

為什麼要修

FAL / Replicate / Suno / Stripe / Orb 5 個 webhook 各自有 HMAC 簽名驗證，但無 idempotency 機制。

現在怎樣

外部服務有時會 retry 同一個事件（網路問題、確認超時），我們的 webhook 路由會重複處理（再次扣點、再次發通知、再次入庫）。

問題在哪

重複扣點、重複入庫、使用者點數異常消耗。

要改什麼

新增 webhook_receipts 表（provider + external_id 唯一索引），所有 webhook 路由前掛 middleware 檢查「我收過了沒」。

涉及檔案

drizzle/migrations/00XX_webhook_receipts.sql（新增）

drizzle/schema.ts（新增 webhookReceipts 表）

server/middleware/webhookIdempotency.ts（新增）

server/routers.ts（5 個 webhook 路由前掛 middleware）

Claude Code 提示詞 (複製貼上)

把下面這段話完整複製，貼到 Claude Code (或 /claude 對話)。Claude Code 會依此完成此項修復。完成後跑下方驗證步驟確認。

請依照計畫附錄 A.11 實作 D-PO-4 Webhook idempotency：

1. 新增 migration drizzle/migrations/00XX_webhook_receipts.sql (取下一個可用編號)：

```
```sql
CREATE TABLE webhook_receipts (
 id BIGINT PRIMARY KEY AUTO_INCREMENT,
 provider VARCHAR(32) NOT NULL,
 external_id VARCHAR(255) NOT NULL,
 payload_hash VARCHAR(64) NOT NULL,
 received_at TIMESTAMP NOT NULL DEFAULT CURRENT_TIMESTAMP,
 processed_at TIMESTAMP NULL,
 status ENUM('received','processed','failed') DEFAULT 'received',
 error TEXT NULL,
 UNIQUE KEY uq_provider_external (provider, external_id),
 INDEX idx_provider_received (provider, received_at)
);
```
```

2. 在 drizzle/schema.ts 新增 webhookReceipts 表 schema。

3. 新增 server/middleware/webhookIdempotency.ts：

```
```typescript
export async function checkWebhookIdempotency(provider: string) {
 return async (req, res, next) => {
 const externalId = req.body.request_id ?? req.body.id ?? req.body.event_id;
 if (!externalId) return res.status(400).json({ error: "missing_external_id" });
 const payloadHash = sha256(req.rawBody);
 try {
 await db.insert(webhookReceipts).values({ provider, externalId, payloadHash });
 } catch (err) {
 if (isDuplicateKeyError(err)) {
 logger.info("webhook_duplicate_ignored", { provider, externalId });
 return res.status(200).json({ status: "duplicate_ignored" });
 }
 throw err;
 }
 }
}
```

```
next();
};
}

export async function markWebhookProcessed(provider: string, externalId: string) {
 await db.update(webhookReceipts).set({ processedAt: new Date(), status: "processed" })
 .where(and(eq(webhookReceipts.provider, provider), eq(webhookReceipts.externalId, externalId)));
}

```

4. 在 server/routers.ts 找到所有 webhook 路由 (grep "/webhook/")，在每個路由前掛 checkWebhookIdempotency(providerName)。處理完成後呼叫 markWebhookProcessed。

5. 確保 Express 有保留 rawBody 用於 sha256 (可能需要 raw-body middleware)。

6. 寫一條 vitest 測試：同一個 webhook payload 連送兩次 → 第一次 200、第二次 200 with status "duplicate\_ignored"，且業務邏輯只執行一次。

不要做的事：不要動既有的 HMAC 簽名驗證邏輯（保留作第一層防線）。不要把 webhook\_receipts 設 TTL 自動清除（保留 90 天作審計）。

## 如何驗證做完了

用 curl 連送兩次同一個 FAL webhook payload → 第二次回 200 with duplicate\_ignored，DB 看 generationHistory 只新增一筆、點數只扣一次。

## 預估耗時

1 天